

SQL injection vulnerability allowing login bypass

Topic: SQL Injection | Difficulty: Apprentice

Description

The login form passes user-supplied credentials directly into a SQL query without sanitization or parameterization. By injecting a comment sequence into the username field an attacker can short-circuit the password check and log in as any user, including the administrator account.

Steps to Exploit

1. Navigate to the application login page.
2. Enter `administrator'--` in the username field.
3. Enter any arbitrary value in the password field.
4. Submit the login form.
5. Observe that access is granted as the administrator user.

Proof of Concept

Payload (username field):

```
administrator'--
```

Original Query:

```
SELECT * FROM users WHERE username = 'wiener' AND password = 'password'
```

Modified Query:

```
SELECT * FROM users WHERE username = 'administrator'--' AND password = ''
```

Impact

- Complete authentication bypass for any known username.
- Full administrative access to the application.
- Unauthorized access to sensitive user data and configurations.
- Potential for further privilege escalation and data exfiltration.

Mitigation / Remediation

1. Use parameterized queries or ORM frameworks for all database access.
2. Implement multi-factor authentication to limit impact of credential bypass.
3. Apply server-side input validation on all login parameters.
4. Log and monitor all failed and successful authentication attempts.

CVSS Score

CVSS v3.1: 9.8 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

- Attack Vector: Network - exploitable remotely with no prerequisites.
- Attack Complexity: Low - trivial single-payload injection.
- Privileges Required: None - no account needed.
- User Interaction: None.
- Confidentiality: High - full access to all application data.
- Integrity: High - attacker can modify data as administrator.
- Availability: High - attacker could delete data or disrupt service.